Echelon / LonWorks Firmware Attack Surface & Detection Brief

Echelon / LonWorks Firmware Attack Surface & Detection Brief

Scope: Real firmware material was analysed this pass (2026-10-22), from a **truncated** prior download rather than a completed one. `echelon.com/support/downloads` returns HTTP 200 but its page title is literally `Echelon Account Login` - **access verdict: GATED** at the portal. A partial artefact from an earlier attempt was found on disk and used: `SmartServer_IoT_Update.armv7l.zip`, **153,239,552 bytes** (146.1 MB of a reported ~789 MB target), SHA256 `b5ade74e24533e73339e0d6f31c11f1003a1d4f0b51517976993a85e2d90c0cc`. `unzip -t` fails on it - the central directory is absent, confirming truncation rather than a short-but-complete file. No credentials were used, requested or guessed.

Methodology - recovering a truncated archive. A ZIP missing its central directory still carries each member's name in plaintext in its local file header (`PK` `\x03\x04`, name length at offset +26). Scanning for those signatures recovered **3 members**: `checksum`, `exclude.txt` and `fs.tar.gz` - so the payload is a nested tarball. The `fs.tar.gz` deflate stream was located at offset 635 and stream-inflated with a tolerant `zlib.decompressobj(-MAX_WBITS)` (accepting the truncation error at the tail), yielding **154,172,213 bytes**; that was stream-gunzipped to **372,349,816 bytes (355.1 MB)** of tar stream, and the tar headers were walked manually at 512-byte boundaries so truncation would not abort the walk. **7,326 rootfs members were recovered from a 146 MB partial.**

php2shell context: this brief's PHP determination was driven by CVE-2026-109618 / CVE-2026-109619 ("php2shell", CVSS 9.2, PHP 5.4+, emergency-patched 2026-10-21). Those two IDs are carried here **as supplied by the requester** - they were not independently corroborated against NVD/MITRE in this pass, and no vendor-specific CVE was invented to pair with them.

PHP finding: CONFIRMED ABSENT across the 7,326 recovered members, with a stated coverage limit. Zero members matched `.php`, `php.ini`, `php-cgi`, a `php` path component, or `libphp`. The web stack is **nginx + Node-RED + Python**:

Evidence	Count	Example
nginx config	1	`./usr/bin/apollo/cms_nginx_conf`
Node.js modules	1,070	`./usr/bin/apollo/lim/build/lib/node_modules/`
Python	1,839	`./usr/bin/apollo/cms-watchdog.py`
HTML	4	`./usr/bin/apollo/nred/flow-target/flow-target.html`
PHP	**0**	-

`nred` is Node-RED - the SmartServer IoT's flow-programming UI. That is the management interface, and it is Node, not PHP. **Honest limit:** this covers the recovered 355 MB of rootfs, not the whole image, so PHP could in principle sit in the unrecovered remainder. A PHP interpreter alongside an nginx + Node-RED + Python stack would be architecturally redundant, which makes the finding strong rather than merely suggestive - but completing the download would close it outright.

Fleet exposure

566 devices in the ARNG OT census - the second-largest OT vendor by device count. EOL lineage: Echelon -> Adesto -> Dialog -> Renesas. `adestotech.com` now returns HTTP 403 and the Renesas SmartServer IoT product path returns HTTP 404, so vendor-side firmware and patch continuity is itself a risk worth tracking separately from php2shell.

Status

Item	State
Public firmware download	**No** - portal title `Echelon Account Login`
Firmware acquired	**Partial for SmartServer IoT** (146.1 MB of ~789 MB, truncated) / **complete for legacy i.LON 600** - see the 2026-10-22 section below
Extraction run	**Yes** - 3 ZIP members; 7,326 tar members recovered from the partial
PHP determination	**Confirmed absent** in recovered portion; stack is nginx + Node-RED + Python
CVE research pass	**Not performed** - no CVE IDs asserted here
Default credentials	**Found on legacy i.LON 600** - FTP `ilon` / `ilon`, vendor-documented factory default (566 devices)
Legacy platform	**VxWorks 5.4.2** on MIPS - ~25 years old, no vendor patch path

---

Legacy i.LON 600 — extracted device firmware — 2026-10-22

The requester supplied Echelon legacy installers, which closes the gap left by the truncated SmartServer download: **this is real i.LON 600 device firmware, fully recovered**, not a partial. Ten legacy files were filed into product directories under `firmware-staging/Echelon/LonWorks/` and extracted. `153-0377-01A_iLON600_SP7.exe` is a self-extracting installer carrying a **ZIP at offset** `0x11077` which holds the device image: **i.LON 600 LonWorks/IP Server, version 1.07**.

Why this matters for the fleet: **566 devices** — the second-largest OT vendor in the census.

Platform

Property	Value
Main image	`iLonSystem`, 4,112,464 B
Format	**ELF 32-bit MSB MIPS, MIPS-II, statically linked, not stripped**

Property	Value
OS	**VxWorks 5.4.2** (build toolchain: Wind River **Tornado**, 91 references)
Bootloader	`bootrom.upd` , 443,824 B, EST flat binary
Factory IP	`192.168.1.222/24` , **DHCP disabled**, hostname `iLON600` (`Config.fac`)

The image being **statically linked and not stripped** is an analysis advantage: symbol names survive, which is why the service inventory below is readable at all.

Factory-default FTP credentials — CONFIRMED, from vendor documentation in the image

`iLON600 1.07/Web/forms/Echelon/SetupFactory.htm` , lines 139–140, shipped in the firmware:

```
FTP user name: ilon
FTP password: ilon
```

This is the vendor's own "Restore Factory Defaults" page stating what the reset restores to. So **`ilon` / `ilon` is the documented post-reset credential pair**, and any unit reset to factory and not re-hardened accepts it. Unlike the Axis controllers in this corpus — where every one of 130 accounts ships locked — this is a real, spray-able default on a 566-device population.

Recommended action: treat FTP reachability to any i.LON as the finding. Credential rotation is the fix, but the durable control is network-level: these devices should not expose FTP at all.

Service inventory (symbols and banners recovered from the image)

Service	Evidence
FTP server	`VxWorks FTP server (VxWorks %s) ready.` , `ftpdTask created` , `Starting the FTP server on port %d`
Anonymous/guest FTP	symbol `ftpdAnonymousAllow` ; `Guest login ok, access restrictions apply.`
Account strings	`ilon` , `guest` , `target`
WDB debug agent	`wdbDbgTrap` , `wdbDbgRegsSet` , `wdbDbgTraceModeSet` (43 refs)

Two deliberate non-claims. `ftpdAnonymousAllow` is a *symbol in a statically linked image* — its presence proves the VxWorks FTP daemon was compiled in, **not** that anonymous FTP is enabled at runtime. Likewise the WDB symbols show the Tornado debug agent is **linked**, which is a well-known VxWorks exposure, but **symbols present does not prove the agent is runtime-enabled**; confirming that needs a probe of a real device (WDB is UDP/17185). Both are worth testing on hardware, and neither should be reported as a confirmed exposure on this evidence alone. The `rlogin "wrs"` string is likewise **VxWorks shell help text**, not a configured outbound action.

Build-path information leak

Assertion strings retain full developer build paths and source line numbers, e.g.

```
Assertion failed: _semUplinkData != NULL, file C:\Tornado/target/config/iLON_AU/LonTalkDriver.cpp, li
Assertion failed: relayNumber >= 1 && relayNumber <= 2, file C:\Tornado/target/config/iLON_AU/LedCont
```

Low severity on its own, but it names internal components (`LonTalkDriver`, `LedController`, `nfdc2048`) and confirms the `iLON_AU` board-support package — useful to an attacker building a target model, and a reliable fingerprint for defenders.

VxWorks 5.4.2 — version noted, CVE mapping deliberately not asserted

VxWorks 5.4.2 is a **circa-2000 release**, roughly 25 years old and long out of support. That is itself the finding: a 566-device population running an RTOS with no vendor patch path, compounded by the Echelon → Adesto → Dialog → Renesas lineage already noted above.

No CVE IDs are asserted here. In particular this brief does **not** claim URGENT/11 applicability: that set targets the IPnet stack in later VxWorks branches, and whether this 5.4.2 build is affected was **not** verified in this pass. Mapping 5.4.2 to specific CVEs needs a dedicated research pass against NVD/MITRE and ICS-CERT; until that is done, no ID is listed rather than a plausible-looking one invented.

Corpus status

The legacy catalog is **410 files / 225 distinct SHA256** across i.LON 100/600, OpenLDV, NodeBuilder, IP-852 Config Server, ShortStack, FTXL DevKit, Series 5000 tools and License Wizard, split into per-product catalogs and queried against VirusTotal with the parallel orchestrator.